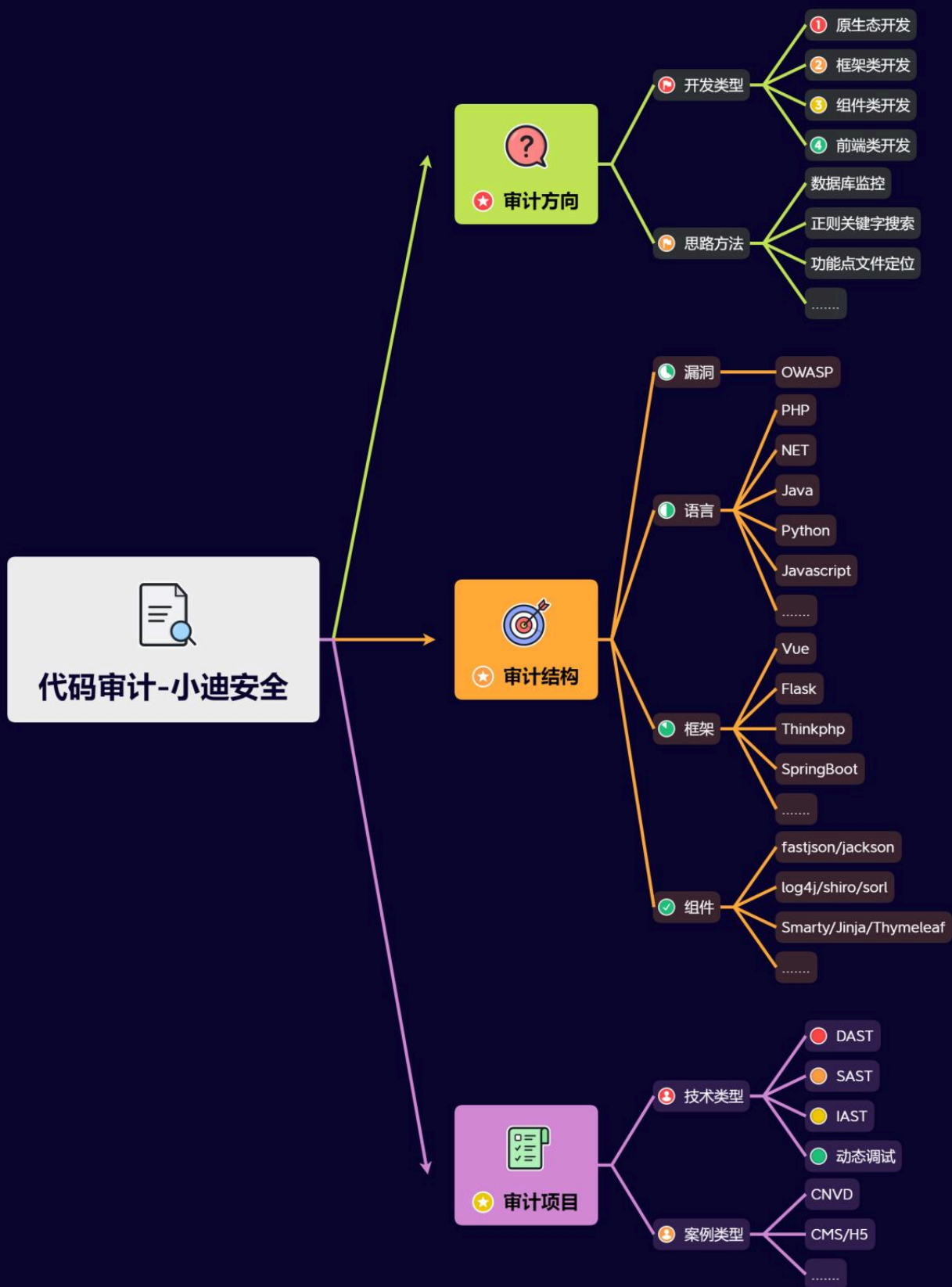


Day107 代码审计-PHP模型开发篇&MVC层 &RCE执行&文件对比法&1day分析&0day验证



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比
-

2.详细点

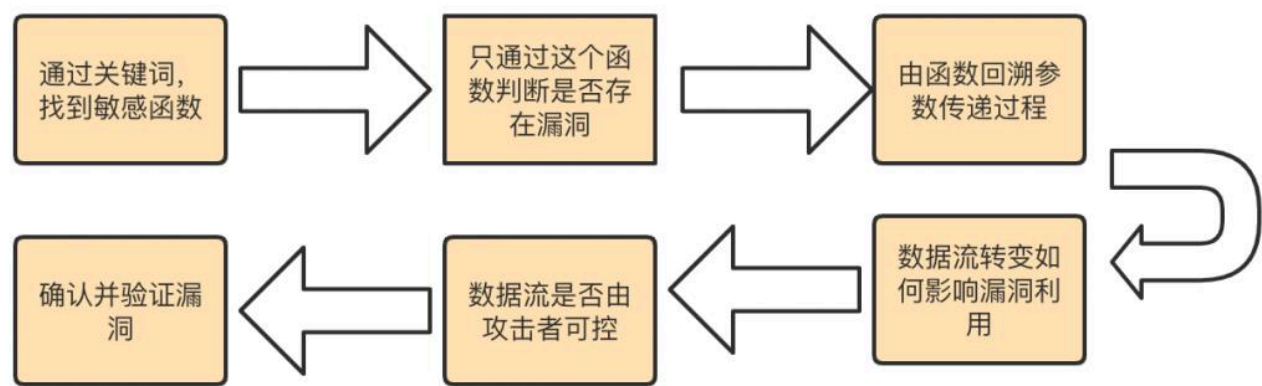
2.1 代码审计分类

- 1、原生态开发-代码审计源码案例
- 2、框架类开发-代码审计源码案例
- 3、组件类开发-代码审计源码案例
- 4、前端类开发-代码审计源码案例

2.2 审计分类

- 1、语言审计-PHP&Net&JS&Java&Python等
 - 2、漏洞审计-注入&RCE&序列化&未授权等
 - 3、框架审计-MVC&Tp&SpringBoot&Flask等
 - 4、组件审计-FastJson&Log4j&Shrio等
 - 5、工具审计-Fortify&Checkmarx&Bandit等
 - 6、技术审计-DAST&SAST&IAST&动态调试等
 - 7、分析审计-CC调用链&内存马原理&JNDI等
-

3.演示案例



函数类型	举例函数或敏感关键词
SQL操作类	Select....., mysql_query...
文件操作类	Move_uploaded_file,copy,/upload/等
命令执行类	System,popen等常见的系统命令做关键词
代码执行类	eval,preg_replace等
引起XSS类	echo等
.....	

功能	出现漏洞类型
文件上传功能	任意文件上传
查询/文章功能	SQL注入
密码找回功能	逻辑漏洞
登陆认证功能	SQL注入，逻辑漏洞
评论功能	XSS漏洞
.....	

MySQL Monitor Client

[首页](#)[使用方法](#)[github仓库](#)[博客](#)

MySQL数据库连接参数

127.0.0.1

3306

root

.....

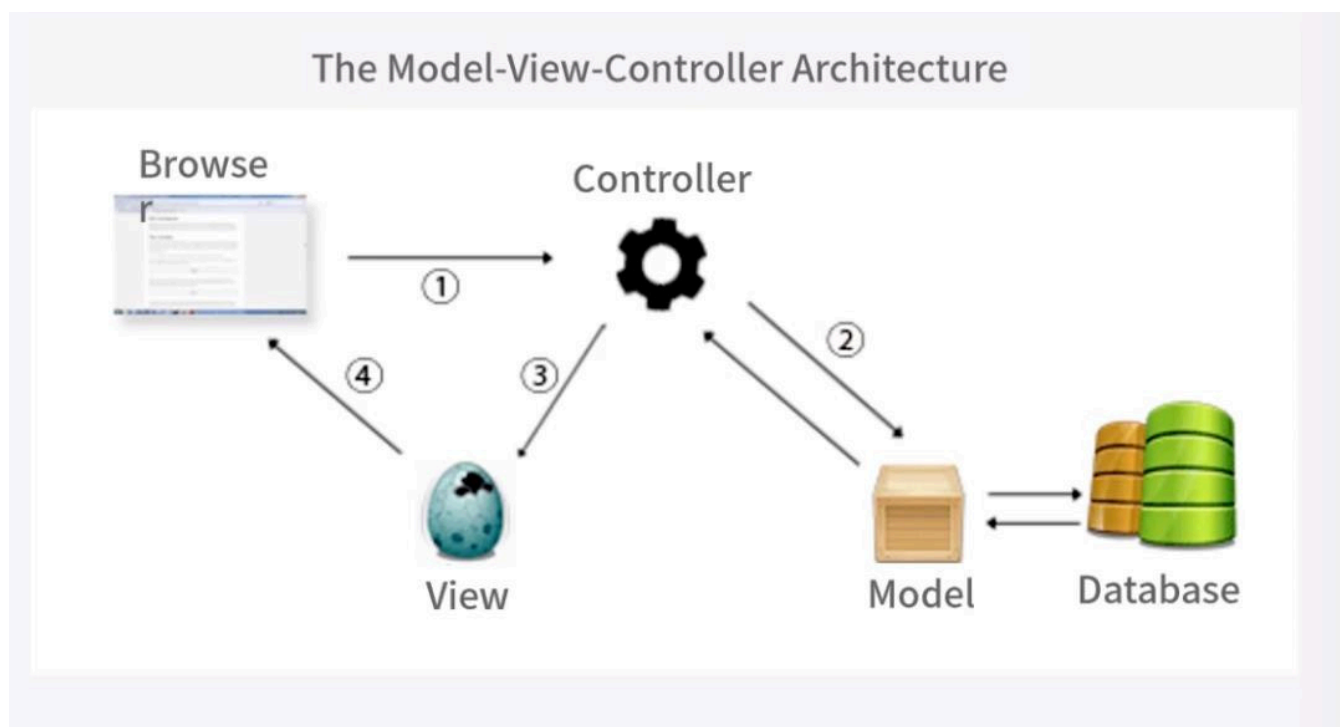
Disconnect

SQL执行记录监控

event_time	user_host	thread_id	server_id	command_type	argument
共 0 条记录					

```
1  #PHP常见漏洞关键字:
2  SQL注入:
3  select insert update mysql_query mysqli等
4  文件上传:
5  $_FILES, type="file", 上传, move_uploaded_file()等
6  XSS跨站:
7  print print_r echo sprintf die var_dump var_export等
8  文件包含:
9  include include_once require require_once等
10 代码执行:
11 eval assert preg_replace call_user_func call_user_func_array等
12 命令执行:
13 system exec shell_exec `` passthru pcntl_exec popen proc_open
14 变量覆盖:
15 extract() parse_str() importrequestvariables() $$ 等
16 反序列化:
17 serialize() unserialize() __construct __destruct等
18 其他漏洞:
19 unlink() file_get_contents() show_source() file() fopen()等
20
21 #通用关键字:
22 $_GET, $_POST, $_REQUEST, $_FILES, $_SERVER等
23
24 MVC开发审计入口常见方法:
25 -搜索法: 常规或部分MVC模型源码可以采用关键字的搜索挖掘思路
26 -功能法: 框架MVC模型源码一般会采用功能点分析抓包追踪挖掘思路
27 -对比法: 可以通过前后修复版本文件及代码不同特征进行针对挖掘思路
28 -特征法: 数据库监控挖SQL注入, 文件监控挖上传删除写入等, 后续补充
29 -工具法: 后续讲到
30 -调试法: 动态调试
```

3.1 PHP审计-MVC开发-控制模块视图



- 1 -MVC流程:
- 2 1、Controller截获用户发出的请求;
- 3 2、Controller调用Model完成状态的读写操作;
- 4 3、Controller把数据传递给View;
- 5 4、View渲染最终结果并呈献给用户。
- 6 -MVC各层职能:
- 7 1、控制器Controller层-负责响应用户请求、准备数据，及决定如何展示数据。
- 8 2、模块Model层-管理业务逻辑和数据库逻辑。提供连接和操作数据库的抽象层。
- 9 3、视图View层-负责前端模版渲染数据，通过HTML方式呈现给用户。
- 10 -MVC对审计主要影响:
- 11 1、文件代码定位问题
- 12 2、代码过滤分析问题
- 13 3、前端安全发现问题

3.2 PHP审计-MVC开发-RCE代码执行



- 1 CNVD-代码执行1day-1mxcms1.40版本
- 2 1、搜索法-RCE
- 3 <https://www.cnvd.org.cn/flaw/show/CNVD-2019-05679>
- 4 `/admin.php?m=Acquisi&a=showCjData&id=1&lid=1&cid=1`
- 5 2、功能法-RCE
- 6 <https://www.cnvd.org.cn/flaw/show/CNVD-2019-05678>
- 7 `TemplateAction.class.php`
- 8 `<{php}> phpinfo();</php>`
- 9 3、对比法拿0day-1.41版本
- 10 UltraCompare对比

3.3 PHP审计-MVC开发-RCE命令执行



```
1  CNVD-命令执行1day-baijiacms4.1.4版本
2  https://www.cnvd.org.cn/flaw/show/CNVD-2021-12800
3  搜索法: system->common.inc.php->file_save->setting.php
4  条件:
5  1、$extention=='txt'
6  2、weixin_verify_file有值
7  3、$settings['image_compress_openscale']=1
8
9  开启image_compress_openscale=1
10 /index.php?mod=site&act=manager&do=netattach
11 上传weixin_verify_file
12 /index.php?mod=site&act=weixin&do=setting
13 触发weixin_verify_file
14 weixin_verify_file filename=&whoami&.txt
```